

SIBER Sicherheits-Scan-Bericht

Ziel: <https://fixture.test.example/>
Profil: Sicherer Scan · Status: Abgeschlossen
Scan-ID: 5b8c81c4-5d8f-465a-8a86-ff9f4d83e733
Beobachtung (Scan): 16.09.2026 11:33 UTC · Bericht erstellt: 16.09.2026 11:33 UTC

Management-Zusammenfassung
Mittlere Verbesserungen werden empfohlen. **Mittel: 1** **Info: 1**

Scan-Umfang

Geplant — Profil	Sicherer Scan
Autorisierung	DNS-Verifizierung
Geplante Scanner	passive_http, sensitive_data, zap, nuclei
Ausgeführt — abgeschlossen	4
Ausgeführt — fehlgeschlagen/Timeout	0
Ausgeführt — URLs	nicht gemessen
Ausgeführt — Befunde	2

Scanner-Ausführung

Scanner	Status	Prüfart	Befunde	Dauer	URLs
passive_http	Abgeschlossen	HTTP/TLS	2	0.80s	nicht gemessen
nuclei	Abgeschlossen	Nuclei	0	2.10s	nicht gemessen

Befundübersicht

Schweregrad	Status	Befunde	Regel
Mittel	Offen	CSP: weite Quellen	generic.csp-wildcard-directive
Info	Offen	X-Powered-By-Header gibt Technologie preis	x-powered-by-disclosure

Befunde (2)

Mittel Status: Offen

CSP: weite Quellen

Quelle: zap · Regel: generic.csp-wildcard-directive

URL: <https://fixture.test.example/>

Was bedeutet das? CSP erlaubt weite Quellen. Das ist ein Konfigurationshinweis, kein bestätigtes XSS. Beobachtete Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:. Keine literale *; beobachtbar sind weite Schema-Quellen.

Nachweis

Kopfzeile: Content-Security-Policy
Beobachteter Wert: default-src 'self'; script-src 'self' 'unsafe-inline';
style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:
Nachweistyp: HTTP-Antwortheader
URL: <https://fixture.test.example/>
Quelle: zap
Regel: generic.csp-wildcard-directive

Lösung: Die beobachtete CSP erlaubt weite Quellen. Das ist keine bestätigte XSS-Ausnutzung. Eine generische CSP als alleinige Lösung kann die Seite brechen.

1. Beobachtete Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:
2. Im gespeicherten Text kommt kein literales * vor — nicht als Stern-Wildcard darstellen.
3. Weite Schema-Quellen (z. B. https: / data: / blob:) sind von einem literalen * zu unterscheiden.
4. Nur die im Nachweis genannten Direktiven verengen; kein Copy-Paste einer Standard-CSP.
5. Zuerst in Staging testen, dann erneut scannen.

Info Status: Offen

X-Powered-By-Header gibt Technologie preis

Quelle: passive_http · Regel: x-powered-by-disclosure

URL: <https://fixture.test.example/>

Was bedeutet das? Erleichtert Angreifern die Zielauswahl.

Nachweis

Kopfzeile: X-Powered-By
Beobachteter Wert: PHP/8.2.0
Nachweistyp: HTTP-Antwortheader
URL: <https://fixture.test.example/>
Quelle: passive_http
Regel: x-powered-by-disclosure

Lösung: X-Powered-By zeigt oft Middleware/Hosting (Passenger, Plesk, PHP) — nicht immer PHP expose_php und nicht IIS, sofern der Wert das nicht belegt.

1. Beobachteter Wert: PHP/8.2.0
2. Welche Schicht den Header setzt, ist ohne Server-Zugriff oft unklar — Proxy-, App- und Panel-Einstellungen prüfen.
3. PHP: expose_php = Off in php.ini — nur weil der Wert PHP nennt.

4. Nach Anpassung erneut scannen und den Header vergleichen.